

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration	3	3	9
Competitor	Steal proprietary business data / intellectual property	2	3	6
Employee	Disrupt mission-critical operations	1	3	3

Approach

The assessment followed the **NIST SP 800-30 framework** to systematically identify threats, vulnerabilities, and potential business impacts.

- **Risk Analysis:** Evaluated the data storage and management methods of the business by analyzing both external threat sources (e.g., hackers, competitors) and internal threat sources (e.g., employees).

- **Scoring Methodology:** Likelihood and severity were evaluated on a **1–3 scale** (1 = Low, 2 = Medium, 3 = High), where the overall Risk Score was calculated as Likelihood x Severity.
- **Operational Impact:** Evaluated potential threats against day-to-day operational needs, regulatory requirements, and the financial impact of database downtime or data exfiltration.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database. Development of robust, encrypted off-site backup protocols alongside centralized monitoring systems to facilitate real-time identification of unauthorized intrusion efforts. Use of SIEM technology to ensure comprehensive auditing and rapid response to security incidents across the infrastructure.